# 結合SonarQube與Gpt4.1於.NET電子商務應用之弱點智慧化分類

# Integrating SonarQube and Gpt4.1 for Intelligent Vulnerability Triage in .NET-Based E-Commerce Applications

研究生：吳思正

指導教授: 譚旦旭 博士

Date: July 9, 2025



TAIPEI TECH

# Agenda

1. Motivation: Scan cost; Developers' burden
2. Research Objective
3. System Architecture: Environment; Implementation; Flowchart; Demo
4. Conclusions: Achievements; Future directions; Limitations

# Motivation (1/4) : Vulnerability scan cost

| Product | Model | Approx. Cost |
|---|---|---|
| **SonarQube** | Self-hosted | Free (Community) + VM cost |
| **SonarCloud** | SaaS | $10/mo/100k LOC |
| **GitHub Adv Sec** | SaaS | $49/user/mo |
| **GitLab Ultimate** | SaaS/self-hosted | $99/user/mo |
| **Snyk** | SaaS | $56/user/mo |
| **Fortify** | SaaS/On-prem | $20,000–$50,000/year* |
| **Veracode** | SaaS | $15,000–$40,000/year* |
| **Mend (WhiteSource)** | SaaS | $10–$20/user/mo |
| **Open-source** | Self-hosted | $0 (SW) + infra |

# Motivation (2/4) : Affordable vulnerability scan

| Step | Est. Cost (USD) |
|---|---|
| SonarQube VM | $0.0048 |
| Blob Storage | < $0.00001 |
| Azure OpenAI GPT-4.1 | $0.33 |
| **Total per Commit** | **$0.335** |

# Motivation (3/4) : Reduce developers' burden

| Line of issues/ Severity Level | Full SonarQube Report | GPT4.1 Summary (Reduced) |
|---|---|---|
| Total lines in report | 7032 | 86 |
| CRITICAL | 12 | 4 |
| MAJOR | 23 | 6 |
| MINOR | 35 | 0 |
| INFO | 8 | 0 |

# Motivation (4/4) : prompt engineering matters

- 1. "Identify the top 10 most severe issues and explain why they are critical."

  "Group issues by file/module and summarize..."

  "Recommend refactoring or remediation..."

- 2. "List the top 10 most severe issues, showing severity, file and line number, rule/key, short description, and why this issue is critical and what could happen if not fixed."



TAIPEI TECH

# Research Objective:

## Rapid CI/CD with Integrated, Developer-Friendly Vulnerability Scanning

- Rapid CI/ CD with security mindset → automation
- Developer-Friendly→ GenAI summarize vulnerability report

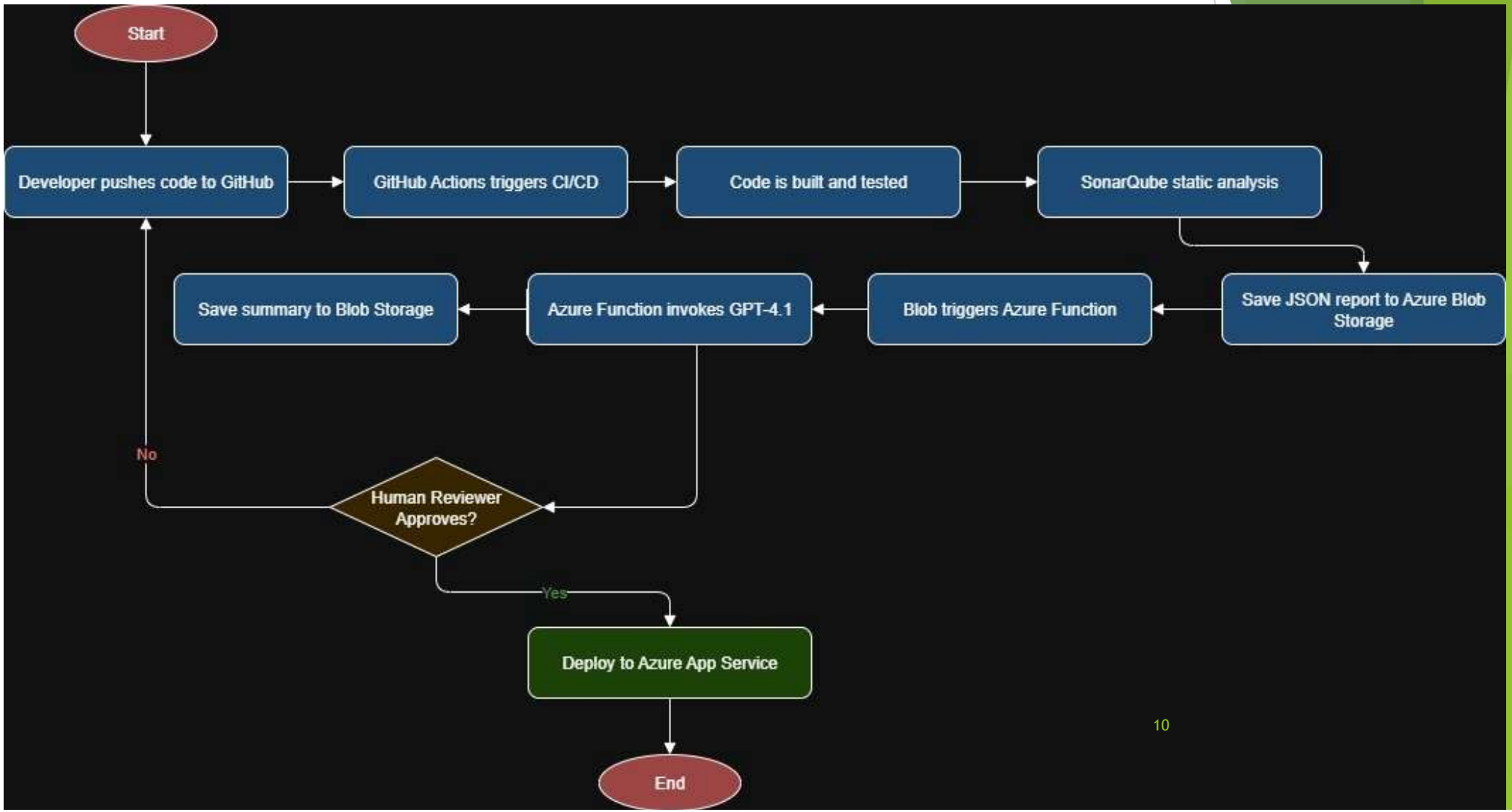
# System Architecture(1/3): Environment

- Application Stack: ASP.NET Core; implementing an e-commerce website provided by Microsoft
- Source Code Repository: GitHub
- CI/CD Orchestration: GitHub Actions
- Static Analysis Tool: SonarQube (Self-hosted) for ASP.NET Core report
- AI Analysis Engine: Gpt-4.1
  1. Azure OpenAI Service
  2. Azure Function
- Deployment Platform: Microsoft Azure App Service

# System Architecture(2/3): Implementation

- Using Github actions, with YAML file to control flow
  - compose workflow under .github directory
- Using Azure Function to trigger Gpt-4.1
  - compose __init__.py to provide prompt and realize Gpt-4.1 summarization logic

# System Architecture(3/3): Flowchart



# Conclusion(1/3): Achievements

- Shift-left security successfully implemented.
- Reliable scanning with SonarQube in self-hosted Azure VM.
- Gpt-4.1 summary improves clarity, reducing developers' burden.
- Human-in-the-loop ensures security control.
- Empirical support for AI in secure coding workflows.

# Conclusion(2/3): Future Directions

- Generalizing Beyond .NET Ecosystem.
- Cost-Effectiveness and Model Benchmarking.
- Fine-Tuning LLMs on Security-Specific Datasets.

# Conclusion(3/3): Limitations

| VM Size | Type | vCPUs | RAM (GiB) | Data disks | Max IOPS | Local storage (GiB) | Premium disk | Cost/month |
|---|---|---|---|---|---|---|---|---|
| NC6s_v3 Request quota | GPU | 6 | 112 | 12 | 20000 | 736 (SCSI) | Supported | $98,444.37 |
| NC12s_v3 Request quota | GPU | 12 | 224 | 24 | 40000 | 1474 (SCSI) | Supported | $196,888.74 |
| NC24rs_v3 Request quota | GPU | 24 | 448 | 32 | 80000 | 2948 (SCSI) | Supported | $433,164.62 |
| NC24s_v3 Request quota | GPU | 24 | 448 | 32 | 80000 | 2948 (SCSI) | Supported | $393,777.48 |
| ND96isr_H100_v5 Request quota | | 96 | 1900 | 16 | 80000 | 28610 (NVMe) | Supported | $3,346,357.47 |
| NV6ads_A10_v5 Request quota | GPU | 6 | 55 | 4 | 6400 | 180 (SCSI) | Supported | $15,445.02 |
| NV12ads_A10_v5 Request quota | GPU | 12 | 110 | 8 | 12800 | 360 (SCSI) | Supported | $30,913.50 |
| NV12s_v3 Request quota | GPU | 12 | 112 | 12 | 20000 | 736 (SCSI) | Supported | $37,086.82 |
| NV18ads_A10_v5 Request quota | GPU | 18 | 220 | 16 | 25600 | 720 (SCSI) | Supported | $54,456.59 |
| NV24s_v3 Request quota | GPU | 24 | 224 | 24 | 40000 | 1474 (SCSI) | Supported | $74,173.63 |
| NV36adms_A10_v5 Request quota | GPU | 36 | 880 | 32 | 51200 | 2880 (SCSI) | Supported | $153,839.87 |
| NV36ads_A10_v5 Request quota | GPU | 36 | 440 | 32 | 51200 | 1440 (SCSI) | Supported | $108,913.18 |
| NV48s_v3 Request quota | GPU | 48 | 448 | 32 | 80000 | 2948 (SCSI) | Supported | $148,347.26 |
| NV72ads_A10_v5 Request quota | GPU | 72 | 880 | 32 | 80000 | 2880 (SCSI) | Supported | $221,910.60 |